

Men's Anonymous Support Platform — Master Specification

Single source of truth combining:

- 1. Concept note (product vision)
- 2. Product rules (anonymity, reveal, session choice)
- 3. Technical architecture (backend design)

Source	Role
Concept note PDF	Why the product exists; services & business model
Product rules	Client-facing anonymity & booking decisions (agreed)
Architecture PDF	How to build it (privacy-first backend)

If these conflict: **product rules win for UX/anonymity behavior; architecture wins for data isolation & security mechanics.**

Part A — Concept (Vision)

A1. Introduction

Men face unique challenges related to personal growth, leadership, and emotional well-being. Societal expectations often discourage men from seeking help. This platform provides **anonymous** virtual counseling, coaching, mentoring, consulting, and support tailored for men — with dignity, privacy, and the option to become known when comfortable.

A2. Objectives

1. **Safe space** — confidential environment without fear of judgment
2. **Diverse services** — counseling, coaching, mentoring, consulting; mental health, personal development, career, relationships
3. **Mental wellness** — normalize prioritizing well-being
4. **Anonymity first** — strict confidentiality; progressive reveal only by client choice

A3. Target audience

- Men of all ages seeking guidance, mentorship, and support
- Professionals / leaders seeking coaching or consulting

A4. Services offered

1. Anonymous virtual counseling
2. Coaching and mentoring
3. Consultation services
4. Support groups (later phase)
5. Resource library (later phase)

A5. Business model

- **Minimum billing** — rate for sessions up to 30 minutes
- **Hourly billing** — after 30 minutes
- **Subscription** (Phase 2+) — monthly plan with a set number of sessions

Primary payment rail (architecture): **M-Pesa** now; Pesapal later.

A6. Marketing (concept-level)

- Awareness campaigns for men's mental health
 - Partnerships with organizations, universities, workplaces
-

Part B — Product Rules (Agreed)

B1. Anonymity is the default

- At registration, every client is **anonymous**: handle / pseudonym only.
- Real identity may live in the **Identity Vault** for recovery and billing.
- Vault PII is **not** visible to counselors, moderators, or other clients unless the client explicitly reveals.

Platform knowing you ≠ counselor knowing you.

B2. Progressive reveal (client-controlled)

Level	What counselor / moderator sees
Anonymous (default)	Handle only
First name	First name + handle
Full name	Full name + handle
Name + photo	Full name + profile photo + handle

- Each step requires **explicit consent**.
- Reveal is **scoped** (session and/or provider relationship), not platform-wide.
- Higher levels include lower ones.

B3. Video while anonymous — allowed

- Client may join **video** while still Anonymous.
- Live face ≠ “known on file.”
- UI still shows handle only until reveal.

B4. Revoke

- Client may lower/revoke reveal for **future** sessions anytime.
- Past sessions keep historical context as it was.
- Revoke does not erase vault records needed for billing, recovery, or compliance.

B5. Who and how (booking)

Client chooses:

1. **Who:** Counselor **or** Moderator
2. **How:** Video or 1:1 chat

Role	Intent
Counselor	Professional counseling / therapeutic support
Moderator	Facilitated support / lighter check-in (not a clinical substitute)

B6. Provider anonymity (asymmetric)

- Providers are anonymous **to clients**.
- Platform must know and verify providers.
- Clients never see provider legal identity in normal flows.

B7. Open product decisions

1. Is "become known" ever **required** for a service type, or always optional?
2. Photo on reveal: profile UI only, or also in live session chrome?
3. Moderator vs counselor: same rates / verification bar?

B8. MVP product bar

Phase 1 must support:

1. Anonymous registration
 2. Book counselor or moderator x chat or video
 3. Video while still anonymous
 4. Progressive reveal (first name → full name → name + photo)
 5. Revoke for future sessions
-

Part C — Technical Architecture

C1. Guiding constraints

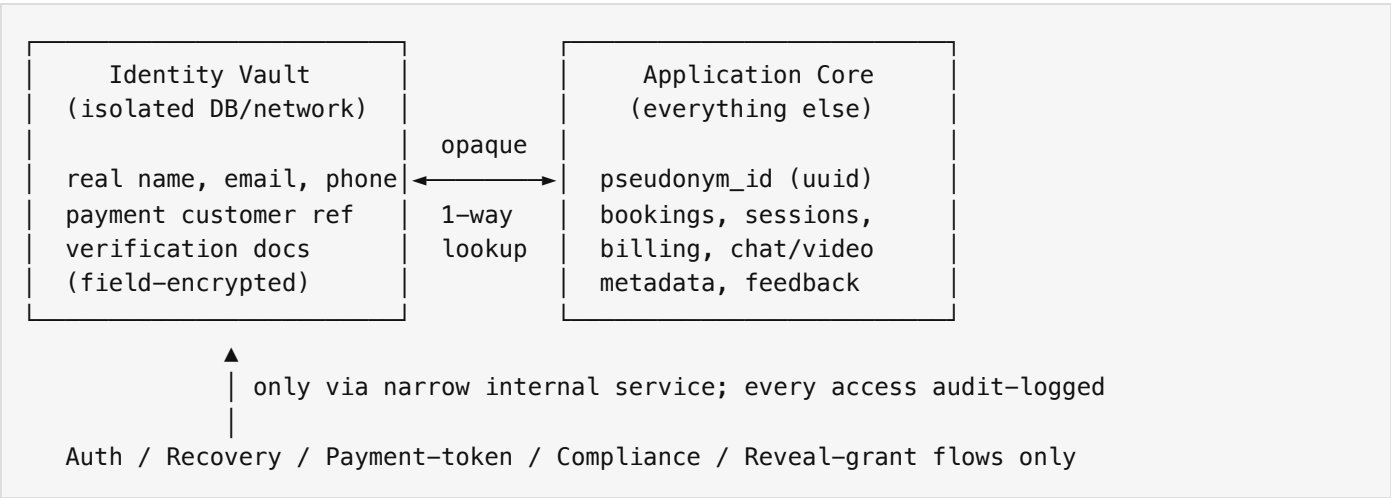
- 1. **Anonymity is a hard requirement** — real identity (name, email, phone, payment method) must never be reachable from the same data path as counseling/session data. If those join in one query, the guarantee is broken.
- 2. **Sensitive-category data** — treat like health data: encryption at rest/in transit, strict access control, audit trails, data minimization.
- 3. Booking, billing, and video are comparatively standard — do not over-engineer them.

C2. Recommended stack

Concern	Choice	Why
Language	TypeScript	Type safety for sensitive fields
Framework	NestJS	Modules, DI, guards map to auth & encryption boundaries
Primary DB	PostgreSQL	ACID; RLS for isolation
Cache/queue	Redis + BullMQ	Sessions, rate limits, jobs
Object storage	S3-compatible (SSE)	Resource assets; never session content by default
ORM	Prisma	Clear schema & migrations
Real-time	Socket.IO + managed WebRTC (Daily / Twilio / Agora)	Avoid self-hosted SFU for MVP
Payments	M-Pesa (Daraja) now, Pesapal later	Common gateway abstraction
Secrets	AWS KMS or HashiCorp Vault	Envelope encryption for PII
Infra	Docker → ECS/Fargate or K8s later	Start simple
IaC/CI	Terraform + GitHub Actions	
Observability	Pino (redaction) + Prometheus/Grafana + Sentry (PII-scrubbed)	

Start as a **modular monolith**. Exception: **Identity Vault** is network/schema-isolated from day one.

C3. Identity Vault separation



- Every user is addressed in app core by pseudonym_id.
- Only IdentityVaultService may query vault PII.
- Payments: phone lives in vault; billing refs are opaque (CheckoutRequestID / OrderTrackingId).
- Payment rails see SIM/card identity — accepted boundary, isolated from counseling data.
- **Reveal grants** (Part B) authorize scoped vault reads to a provider for a session/relationship; still audit-logged.

C4. NestJS modules

Module	Responsibility
auth	Pseudonymous signup/login, JWT, optional MFA
identity-vault	Isolated PII service + DB connection
users	Pseudonymous profiles, preferences, reveal grant state (non-PII)
providers	Counselor/moderator profiles, specialties, availability, verification <i>result</i>
matching	Need/specialty/availability matching
booking	Scheduling; counselor moderator × chat video
sessions	Ephemeral rooms, short-lived tokens, metadata only
billing	PaymentGateway (M-Pesa / Pesapal); min + hourly
notifications	Generic copy only (no therapy wording on lock screens)
support-groups	Phase 2+
resources	Phase 2+ content library

Module	Responsibility
feedback	Ratings tied to pseudonym + session
admin	Moderation, verification, break-glass vault access
audit	Central audit log

Shared: AES-256-GCM field encryption, RBAC/ABAC guards, request-context audit middleware, PII-scrubbing exception filter.

C5. Key data model (simplified)

App core

- User — id (pseudonym), role, status
- ClientProfile — preferences; **no always-visible real name**
- IdentityRevealGrant — client → provider/session, level (ANONYMOUS|FIRST_NAME|FULL_NAME|NAME_PHOTO), scope, active/revoked, timestamps
- ProviderProfile — displayName, specialties, kind (COUNSELOR|MODERATOR), availability, verificationStatus
- Booking — clientId, providerId, scheduledStart, durationMin, channelType, status
- Session — bookingId, channelType, startedAt/endedAt, externalRoomId (**no content**)
- Payment / Subscription — pseudonym + opaque external refs
- Feedback, AuditLog, Resource, SupportGroup

Vault

- IdentityRecord — encrypted name/email/phone, mpesa ref, password hash
- ProviderVerification — license docs, reviewer, decisions
- VaultAccessLog — actor, reason, target, timestamp

C6. Security baseline

- TLS everywhere, HSTS, strict CSP
- Field-level AES-256-GCM (envelope via KMS) for vault PII
- Default: **do not persist chat/video content** server-side
- RBAC + ABAC; break-glass vault access time-boxed, justified, dual-control if possible
- Rate limiting / brute-force protection on auth
- Retention + right-to-delete (vault delete + cascade-anonymize core)
- No production PII in logs

C7. Folder structure

```

apps/
  api/                # NestJS
  worker/             # BullMQ jobs
libs/
  shared/             # DTOs / enums / types
infra/
  docker/
  terraform/
docs/
  concept-note.pdf
  architecture.pdf
  product-rules.md
  platform-master-spec.md # this file

```

C8. Phased roadmap

Phase	Scope
1 — MVP	Pseudonymous auth, vault, profiles, booking (counselor/moderator × chat/video), one video provider, M-Pesa pay-per-session (min + hourly), progressive reveal + revoke, generic notifications
2	Support groups, resource library, feedback/ratings, matching queue, subscriptions (or Pesapal if auto-renew needed)
3	Full admin RBAC, provider verification workflows, break-glass, payouts (B2C), aggregate analytics
Later	Deeper E2E / compliance hardening as jurisdiction requires

C9. Admin portal (minimum roles)

- Support agent — booking/session help; no vault
- Moderator (staff) — content/abuse; no vault
- Compliance officer — provider verification; break-glass vault
- Super admin — roles & system config

Every admin action that touches a user (suspend, refund, vault access) writes to `audit`. Analytics use aggregate read models only.

C10. Provider registration & request handling

Anonymity is **client-facing**, not platform-facing for providers.

1. Sign up → pseudonym + vault contact (pending)
2. Credential intake → encrypted docs
3. Compliance review

4. Approved → public pseudonymous profile (kind: counselor or moderator)
5. Active → availability + bookings

Hybrid request model

- **Direct booking** (default 1:1) — browse profiles, book open slot
- **Auto-match queue** — “get me someone now” / crisis-adjacent / groups

Provider dashboard: requests, calendar, session history (client pseudonym or reveal level only), earnings. Push/email copy stays generic.

C11. Payments — M-Pesa now, Pesapal later

- PaymentGateway: `initiateCharge`, `handleCallback`, `queryStatus`, `payout`
- STK Push is async → records start pending, settle on callback
- Idempotency via `CheckoutRequestID` / `MerchantRequestID`
- Reconciliation job polls stuck pendings
- B2C payouts need separate Safaricom onboarding lead time
- Public HTTPS callback URL required (tunnel/staging early)
- No native M-Pesa recurring → Phase 1 pay-per-session; subscriptions Phase 2 (re-prompt or Pesapal)

C12. Open architecture decisions

1. Managed video vs self-hosted SFU
 2. Persist any session content (even encrypted) vs metadata-only
 3. Jurisdiction compliance target (GDPR-style / HIPAA-adjacent / “act like it”)
 4. Direct-book vs auto-match as default for 1:1
 5. Provider verification rigor at launch
-

Part D — How the pieces fit

Product need	Implementation
Anonymous registration	Create User + vault record; no reveal grants
Progressive reveal	IdentityRevealGrant + audited vault field projection to provider UI
Video while anonymous	channelType=VIDEO; no reveal required
Revoke	Deactivate grant; future sessions fall back to handle; history immutable
Counselor vs moderator	ProviderProfile.kind
Chat vs video	Booking/Session.channelType
Min 30 + hourly	Billing module; M-Pesa STK
Never leak therapy context in SMS/email	Notifications module generic templates only

Part E — Working agreement

1. This master spec is the combined view for product + engineering.
2. Keep short living companions if needed: `product-rules.md` for product-only edits; `architecture.pdf` as the original backend write-up.
3. Before coding a phase, resolve Part B7 and C12 items that block that phase.
4. Do not ship a join path from session data → vault PII without an active reveal grant + audit row.